Audit Readiness Assessment

1. SOC 2 Evidence Review Summary

System profile used across this portfolio: FinanceGuard AI is a fine-tuned LLM used for financial document review. It processes PII and confidential financial data through an internal API gateway and operates across a hybrid cloud environment. Current-state evidence indicates incomplete data lineage, monitoring, impact assessment, adversarial testing, transparency, and retention enforcement. These assumptions drive the control ratings and the Conditional Go recommendation.

Control ID	Trust Services Criteria (TSC)	Control Description (FinanceGuard AI Context)	Provided Audit Artifact/ Evidence	Evidence Evaluation & Status (Pass/Partial/Fail)
CC6.1	**Security:** Access Transmission	The internal API gateway restricts model access to authorized compliance and legal user groups, encrypting PII/financial data in transit.	API gateway RBAC export; authorized-group roster; MFA configuration; TLS configuration; quarterly access-review record.	**PARTIAL — Access restriction and encryption are described, but operating-effectiveness evidence and recertification records are incomplete. This aligns to GAP-01 and ISO A.8.3 Partial.**
CC6.3	**Security:** Perimeter Defense	Hybrid cloud infrastructure endpoints hosting the fine-tuned LLM are hardened against unauthorized access and prompt injection.	Independent vulnerability scan; endpoint hardening baseline; prompt-injection/adversarial test report; model-weight change log; remediation tickets.	**FAIL — No complete evidence demonstrates hybrid-cloud hardening or resistance to prompt injection and unauthorized model changes. This aligns to GAP-02 and ISO A.8.3 Partial.**
CC7.1	**Confidentiality:** Data Retention & Disposal	Confidential financial documents and temporary session data processed by the LLM are purged or encrypted according to corporate retention schedules.	Approved retention schedule; data-flow inventory; encryption evidence; automated purge configuration; deletion logs; exception register.	**FAIL — Retention and disposal cannot be validated across PII-bearing hybrid-cloud flows. This aligns to GAP-01 and ISO A.5.2 Gap.**

2. CISO Executive Recommendation

To: Chief Information Security Officer (CISO)

From: AI Governance Program Lead

Date: July 8, 2026

Subject: SOC 2 Audit Readiness Assessment & Recommendations for FinanceGuard AI

Decision: CONDITIONAL GO for continued limited deployment; NO scaling or external-audit assertion until exit criteria are met. FinanceGuard AI has a defensible business use, but its current evidence package does not yet demonstrate that PII and confidential financial data are consistently protected across the hybrid-cloud lifecycle. The most consequential exposures are incomplete data lineage and deletion proof, insufficient operating evidence for API and model security, and the absence of a completed impact assessment. These weaknesses create avoidable risk of unauthorized disclosure, inconsistent retention, unreliable regulatory filings, and an adverse audit conclusion.

The CISO should permit only the existing bounded use case with no new data sources, user groups, integrations, or production regions. Within the remediation window, the AI Program Lead must maintain the risk register and evidence plan; the Data Steward must complete lineage, minimization, retention, and deletion validation; Cyber Security must complete prompt-injection, vulnerability, access-control, and logging tests; and the Model Owner must approve the impact assessment, model card, limitations, and human-review requirements.

Exit criteria are: CC6.1 upgraded to Pass through access and encryption operating evidence; CC6.3 and CC7.1 upgraded from Fail to Pass; all High gaps closed; and independent validation by External Audit Partners. Any confirmed PII exposure, failure to meet a milestone, or inability to produce complete evidence should trigger suspension and Steering Committee review. Scaling may proceed only after the CISO accepts residual risk in writing.